

Kaval Online — Low-Level Technical Document

Architecture, Implementation Details & Developer Reference

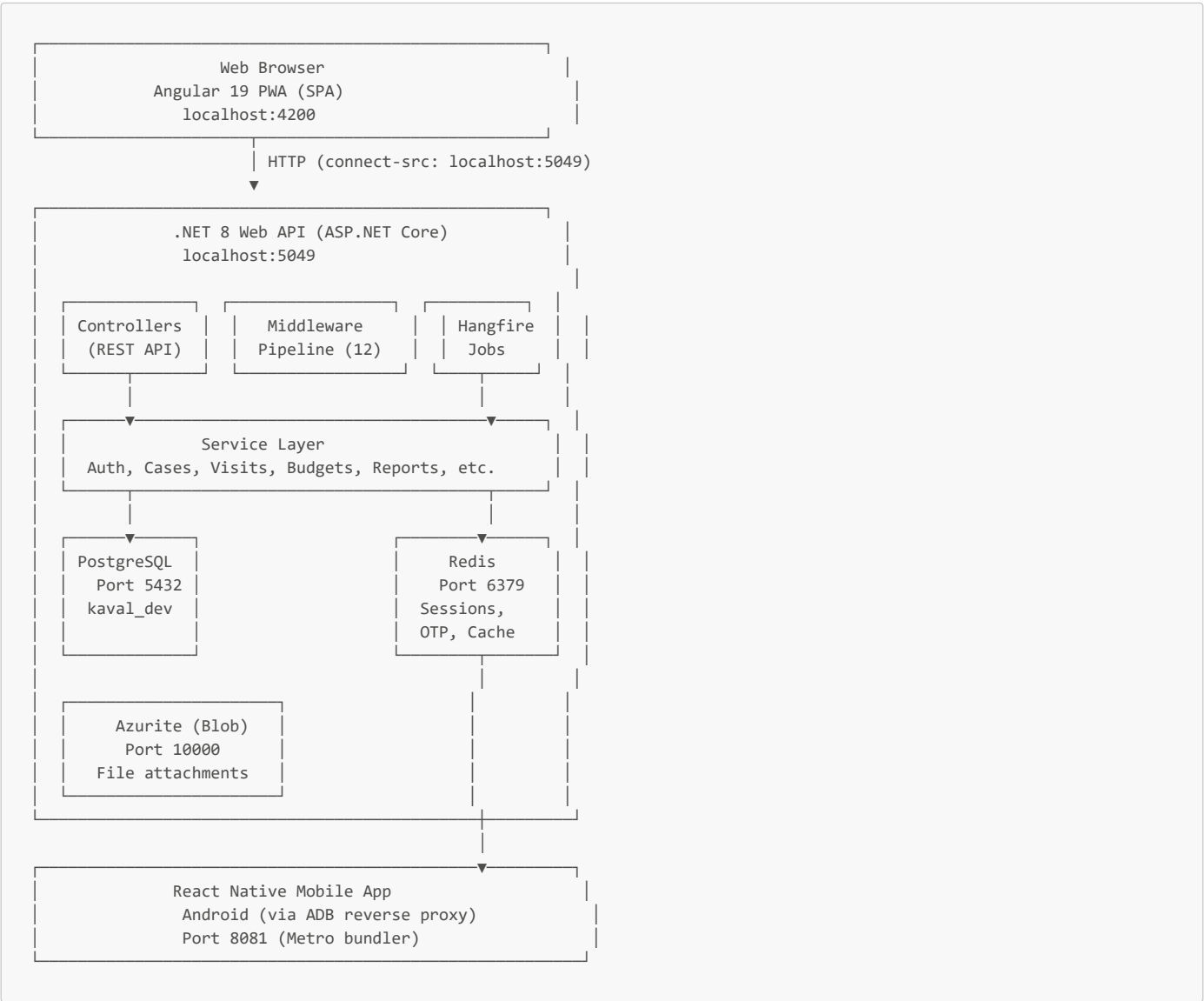
Version 1.0.0

Table of Contents

- 1. [System Architecture](#)
- 2. [Project Structure](#)
- 3. [API Layer](#)
- 4. [Database Schema & Migrations](#)
- 5. [Authentication & Authorization](#)
- 6. [Middleware Pipeline](#)
- 7. [Background Jobs](#)
- 8. [Web Frontend Architecture](#)
- 9. [Mobile App Architecture](#)
- 10. [Infrastructure & DevOps](#)
- 11. [Security & Compliance](#)
- 12. [Development Setup](#)
- 13. [Testing Strategy](#)

1. System Architecture

1.1 High-Level Architecture



1.2 Technology Stack Summary

Layer	Technology	Version
API Framework	ASP.NET Core	8.0
ORM	Entity Framework Core + Npgsql	8.0.11
Database	PostgreSQL	16
Cache / Session	Redis (StackExchange.Redis)	7
Blob Storage	Azure Blob Storage / Azurite	12.23.0
Web Frontend	Angular (standalone components)	19.2
Mobile	React Native	0.76.9
Background Jobs	Hangfire	1.8.23
Authentication	JWT Bearer + OTP.NET	8.3.0 / 1.4.1
Email	MailKit (SMTP)	4.11.0
PDF Generation	QuestPDF	2024.12.3
Excel Generation	ClosedXML	0.104.2
Push Notifications	Firebase Admin SDK	3.2.0

1.3 Solution Structure

The .NET solution file (`Midi-Kaval.slnx`) uses the modern `.slnx` XML format:

```
Midi-Kaval.slnx
├─ apps/api/MidiKaval.Api.csproj
├─ tests/api.unit/MidiKaval.Api.UnitTests.csproj
└─ tests/api.integration/MidiKaval.Api.IntegrationTests.csproj
```

2. Project Structure

2.1 Repository Layout

```
Midi-Kaval/
├─ .agents/           # Cursor AI agent skills & config
├─ _bmad-output/      # BMad project management artifacts
├─ apps/
│   └─ api/           # .NET 8 Web API
│       ├── Authorization/ # Custom authorization handlers
│       ├── Controllers/V1/ # API controllers by feature
│       ├── Domain/       # Domain entities & services
│       ├── Infrastructure/ # Cross-cutting: auth, storage, middleware, etc.
│       ├── Migrations/   # EF Core migrations (44 total)
│       ├── Models/       # Request/Response DTOs
│       └─ Jobs/         # Hangfire background job runners
│   └─ mobile/         # React Native app (npm workspace)
│   └─ web/            # Angular PWA (npm workspace)
├─ infra/
│   └─ docker-compose.yml # PostgreSQL 16, Redis 7, Azurite
├─ packages/
│   └─ shared-types/     # Shared TypeScript types (npm workspace)
├─ scripts/             # Dev setup batch scripts
├─ tests/
│   ├── api.unit/        # xUnit unit tests
│   └─ api.integration/  # xUnit integration tests
└─ package.json          # Root npm workspace config
```

2.2 API Internal Structure (`apps/api`)

```
MidiKaval.Api/
├─ Authorization/
│   ├── Require2FAAttribute.cs # [Require2FA] action filter
│   └─ ActiveUserRequirement.cs # Authorization handler
```

```

└─ InactiveUserAuthConstants.cs # Shared constants
└─ Controllers/V1/
  └─ AuthController.cs # Login, OTP, 2FA, password reset
  └─ Auth/TwoFactorController.cs # TOTP enrollment & verification
  └─ CasesController.cs # Case CRUD, search, lifecycle
  └─ VisitsController.cs # Visit scheduling & management
  └─ NotesController.cs # Case notes
  └─ InterventionsController.cs # Interventions CRUD
  └─ CourtSittingsController.cs # Court schedule
  └─ TravelClaimsController.cs # Travel claims
  └─ BudgetsController.cs # Budget lifecycle
  └─ StaffController.cs # Staff directory
  └─ Admin/
    └─ UsersController.cs # User management
    └─ InvitationsController.cs # Invitations
    └─ AuditController.cs # Audit log
    └─ ... # Migration, Legends, etc.
  └─ Vendor/OrganisationsController.cs # Vendor org management
  └─ SyncController.cs # Offline sync
  └─ NotificationsController.cs # In-app & push notifications
  └─ ReportsController.cs # Report generation
  └─ AttachmentsController.cs # File upload/download
  └─ SecurityController.cs # CSP violation reports
└─ Domain/
  └─ Entities/ # EF Core entity classes
    └─ User.cs
    └─ Case.cs
    └─ Organisation.cs
    └─ CaseStage2Data.cs through CaseStage6Data.cs
    └─ ... (20+ entities)
  └─ RoleManagement/ # Domain services
    └─ RegistrationService.cs
    └─ InvitationService.cs
    └─ UserManagementService.cs
    └─ TwoFactorService.cs
    └─ ...
  └─ UserRoles.cs # Role constants
└─ Infrastructure/
  └─ Auth/ # Authentication infrastructure
    └─ AuthService.cs # Core auth logic
    └─ JwtTokenService.cs # JWT creation/validation
    └─ OtpChallengeStore.cs # Redis-backed OTP storage
    └─ RefreshTokenStore.cs # Redis-backed refresh token storage
    └─ AuthVerifiedStore.cs # Step-up verification store
    └─ DualAuthOptions.cs # Dual auth migration config
    └─ AuthClaimTypes.cs # Custom JWT claim constants
  └─ Middleware/
    └─ RequestIdMiddleware.cs
    └─ ContentSecurityPolicyMiddleware.cs
    └─ TokenVersionMiddleware.cs
    └─ SuspendedUserMiddleware.cs
    └─ ApiProblemDetailsMiddleware.cs
  └─ Persistence/
    └─ AppDbContext.cs # EF Core DbContext
  └─ Seed/
    └─ DatabaseInitializer.cs # Migration + seeding orchestrator
    └─ AdminUserSeeder.cs # Director seed
    └─ VendorUserSeeder.cs # Vendor seed
    └─ FieldWorkerUserSeeder.cs # Field worker seed
    └─ PocsoCaseSeeder.cs # Dev POCSO case seed
  └─ Cases/ # Case service implementations
  └─ Storage/
    └─ AzureBlobStorageService.cs
    └─ BlobStorageOptions.cs
  └─ Email/SmtpEmailSender.cs # MailKit integration
  └─ Migration/ # Legacy data import
  └─ Reports/ # Report generation services
└─ Migrations/ # 44 EF Core migrations
└─ Models/ # DTOs
└─ Jobs/ # Hangfire job runners
└─ Program.cs # Application entry point
└─ appsettings.json # Base config
└─ appsettings.Development.json # Dev overrides

```

3. API Layer

3.1 Startup Pipeline (Program.cs)

The startup sequence in Program.cs follows this order:

1. Configuration & Services Registration
- QuestPDF license (Community)
 - Controllers with ApiEnvelopeFilter
 - JSON serialization options (camelCase, ignore null)
 - ProblemDetails + ExceptionHandler
 - EF Core DbContext with Npgsql + SnakeCase naming
 - IPasswordHasher<User> (ASP.NET Core Identity)
 - All service registrations (scoped/singleton)
 - Blob storage, Auth, Rate limiting, CORS, Security
 - Hangfire (PostgreSQL or In-Memory)
 - Swagger/OpenAPI
2. Middleware Pipeline (order matters — see §6)
3. Migration & Seeding (AppDbContext.Database.MigrateAsync())
- All 44 migrations applied on startup
 - Seeders run after migrations
4. Dual-Auth Migration (conditional, RUN_MIGRATION=1 env var)
5. Application Start (app.Run())

3.2 Response Envelope

All API responses (except ProblemDetails) are wrapped in an envelope:

```
{
  "data": { ... },
  "meta": {
    "requestId": "3ef3f9f9-e94e-4f10-b897-62efc887f2ef"
  }
}
```

Implemented by ApiEnvelopeFilter (action filter on all controllers).

3.3 API Versioning

- All routes are under /api/v1/
- No explicit versioning strategy yet — uses URL path convention
- Future versions will add /api/v2/ as needed

3.4 Rate Limiting

Policy	Endpoints	Limit	Partition
auth-login	Login	10/60s per IP	IP
auth-verify	Verify OTP	10/60s per IP	IP
auth-refresh	Refresh token	10/60s per IP	IP
auth-logout	Logout	10/60s per IP	IP
auth-*	All auth	10/60s per IP	IP
data-read	GET requests	100/60s per IP (Directors bypass)	IP
data-write	POST/PUT/DELETE	20/60s per IP (Directors bypass)	IP
vendor-create	Vendor write	10/60s per user	User ID/IP
vendor-read	Vendor read	60/60s per user	User ID/IP

3.5 Audit Events

All significant actions are recorded in audit_events table:

Event Type	When
login_success	Successful password+OTP login
login_failed	Failed login attempt
otp_failed	Wrong OTP code
refresh_success	Token refresh
logout	Explicit logout
password_reset_requested	Forgot password initiated
password_reset_completed	Password successfully reset
user_suspended	User suspended by Director
user_reactivated	User reactivated
user_deleted	User deleted
case_created	New case registered
visit_scheduled	Visit scheduled
visit_completed	Visit completed
claim_submitted	Travel claim submitted
claim_approved	Travel claim approved
budget_proposed / budget_approved / ...	Budget lifecycle events

3.6 Error Handling

Standardized error responses using RFC 9457 (Problem Details):

```
{
  "type": "https://tools.ietf.org/html/rfc7231#section-6.5.1",
  "title": "Unauthorized",
  "status": 401,
  "detail": "Invalid email or password."
}
```

Implemented via `GlobalExceptionHandler` + `ApiProblemDetailsMiddleware`:

Middleware	Status	Scenario
ExceptionHandler	500	Unhandled exceptions
ApiProblemDetailsMiddleware	Various	Ensures ProblemDetails format
TokenVersionMiddleware	401	Token version mismatch (session revoked)
SuspendedUserMiddleware	403	Account suspended
Require2FAAttribute	403	2FA required but not enrolled
RateLimiter	429	Rate limit exceeded

4. Database Schema & Migrations

4.1 EF Core Approach

- **DbContext:** `AppDbContext` in `Infrastructure/Persistence/`
- **Naming convention:** SnakeCase via `UseSnakeCaseNamingConvention()`
- **Migrations:** Auto-generated, 44 total, applied automatically on startup
- **Key migrations** (order matters — see `__EFMigrationsHistory`):

Migration ID	Description
20260614034204_InitialUsers	Users, organisations
20260614120000_AddAuditEvents	Audit event tracking
20260615025857_AddCases	Case entity

Migration ID	Description
20260615060716_AddCaseStages	Stage transitions
20260615161135_AddCaseSearchSupport	Search presets
20260615204455_AddCaseAssignments	Case-worker assignments
20260616134617_AddVisits	Visit scheduling
20260618033602_AddSyncMutations	Offline sync
20260619034212_AddInterventions	Interventions
20260619040743_AddInAppNotificationsAndOverdueFlag	Notifications
20260619120253_AddCourtSittings	Court schedule
20260620002443_AddTravelClaims	Travel claims
20260620020511_AddUserDevices	Push notification devices
20260620141629_AddStaffDirectoryFields	Staff name/phone fields
20260620202159_AddCaseGenderFamilyTypeEconomicStatus	Case demographics
20260621041034_AddCaseStage2Data	Stage 2 sub-records
20260621064328_AddCaseStage3Support	Stage 3 support records
20260621074218_AddCaseStage4Placement	Stage 4 placement
20260621080747_AddCaseStage5Reintegration	Stage 5 reintegration
20260621091720_AddCaseStage6TerminationExclusion	Stage 6 termination
20260621105452_AddCaseRelatedCases	Case linking
20260621133417_AddBudgetSchema	Budget + line items
20260621134834_AddBudgetUtilizations	Budget utilization
20260622152012_EncryptPiiColumns	PII column encryption
20260623023717_AddCaseActiveLegalStay	Legal stay tracking
20260623182928_AddOrganisationsAndActivationTokens	Org activation
20260623211741_AddActivationTokenDeliveryAttempts	Token delivery
20260624152225_AddInvitations	User invitations
20260627121411_AddConfirmationTokens	Email confirmation
20260627183548_AddUniquePendingConfirmationTokenIndex	Partial index
20260628103532_AddAuditEventTargetSnapshotAndIp	Audit enrichments
20260628153134_AddAuditDigestEntries	Digest system

4.2 Entity Summary (40+ tables)

Core entities:

Table	Key Columns	Relationships
users	id, org_id, email, role, password_hash, is_active, token_version, totp_secret	→ organisations
organisations	id, name, is_active, has_pending_recovery	← users, cases, etc.
cases	id, org_id, crime_number, st_number, beneficiary_name(encrypted), current_stage	→ organisations, users
case_stages	id, case_id, from_stage, to_stage	→ cases
case_assignments	case_id, user_id	→ cases, users
visits	id, case_id, scheduled_at, status, gps_lat/lng	→ cases
interventions	id, case_id, type, provider, provided_status	→ cases
court_sittings	id, case_id, court_date, judge, outcome	→ cases
travel_claims	id, user_id, amount, status, receipt_blob_path	→ users
budgets	id, org_id, financial_year, source, approval_status	→ organisations

Table	Key Columns	Relationships
<code>budget_line_items</code>	<code>id</code> , <code>budget_id</code> , <code>budget_head</code> , <code>amount</code>	→ budgets
<code>budget_utilizations</code>	<code>id</code> , <code>line_item_id</code> , <code>amount</code> , <code>date</code> , <code>description</code>	→ budget_line_items
<code>audit_events</code>	<code>id</code> , <code>org_id</code> , <code>event_type</code> , <code>actor_user_id</code> , <code>metadata_json</code>	→ organisations, users
<code>attachments</code>	<code>id</code> , <code>case_id</code> , <code>blob_path</code> , <code>content_type</code>	→ cases
<code>sync_mutations</code>	<code>id</code> , <code>user_id</code> , <code>entity_type</code> , <code>mutation_type</code> , <code>payload</code>	→ users
<code>invitations</code>	<code>id</code> , <code>org_id</code> , <code>email</code> , <code>role</code> , <code>token_hash</code> , <code>status</code>	→ organisations
<code>confirmation_tokens</code>	<code>id</code> , <code>user_id</code> , <code>token_hash</code> , <code>expires_at</code>	→ users, invitations
<code>activation_tokens</code>	<code>id</code> , <code>org_id</code> , <code>token_hash</code> , <code>status</code>	→ organisations

Case stage data tables (one per stage):

Table	Purpose
<code>case_stage2_data</code>	Bio-psycho-social assessment, group work, ICP records
<code>case_stage3_supports</code>	Support services provided
<code>case_stage4_placement</code>	Placement details
<code>case_stage5_reintegration</code>	Reintegration tracking
<code>case_stage6_termination_exclusion</code>	Termination/exclusion records
<code>case_related_cases</code>	Case-to-case linkages

Legend tables (reference data):

`legend_areas`, `legend_classifications`, `legend_court_outcomes`, `legend_designations`, `legend_education_levels`, `legend_intervention_categories`, `legend_occupations`, `legend_offence_types`, `legend_police_stations`, `legend_visit_outcomes`

4.3 Key Indexes

Table	Index	Type
users	<code>ix_users_organisation_id_email</code>	UNIQUE
cases	<code>ix_cases_organisation_id_crime_number</code>	UNIQUE
cases	<code>ix_cases_organisation_id_st_number</code>	UNIQUE
audit_events	<code>ix_audit_events_organisation_id_created_at_utc</code>	B-tree
audit_events	<code>ix_audit_events_event_type_created_at_utc</code>	B-tree
confirmation_tokens	<code>ix_confirmation_tokens_user_id_pending</code>	UNIQUE partial WHERE consumed IS NULL
audit_digest_entries	<code>ix_audit_digest_entries_audit_event_id</code>	UNIQUE
budget_line_items	<code>ix_budget_line_items_project_budget_id_budget_head</code>	UNIQUE
project_budgets	<code>ix_project_budgets_organisation_id_financial_year_start_source</code>	UNIQUE

4.4 PII Encryption

Migration: `20260622152012_EncryptPiiColumns`

Columns stored as `bytea` (encrypted at the application layer):

Table	Encrypted Columns
cases	<code>beneficiary_name</code> , <code>beneficiary_contact</code> , <code>landmark</code> , <code>longitude</code> , <code>latitude</code>

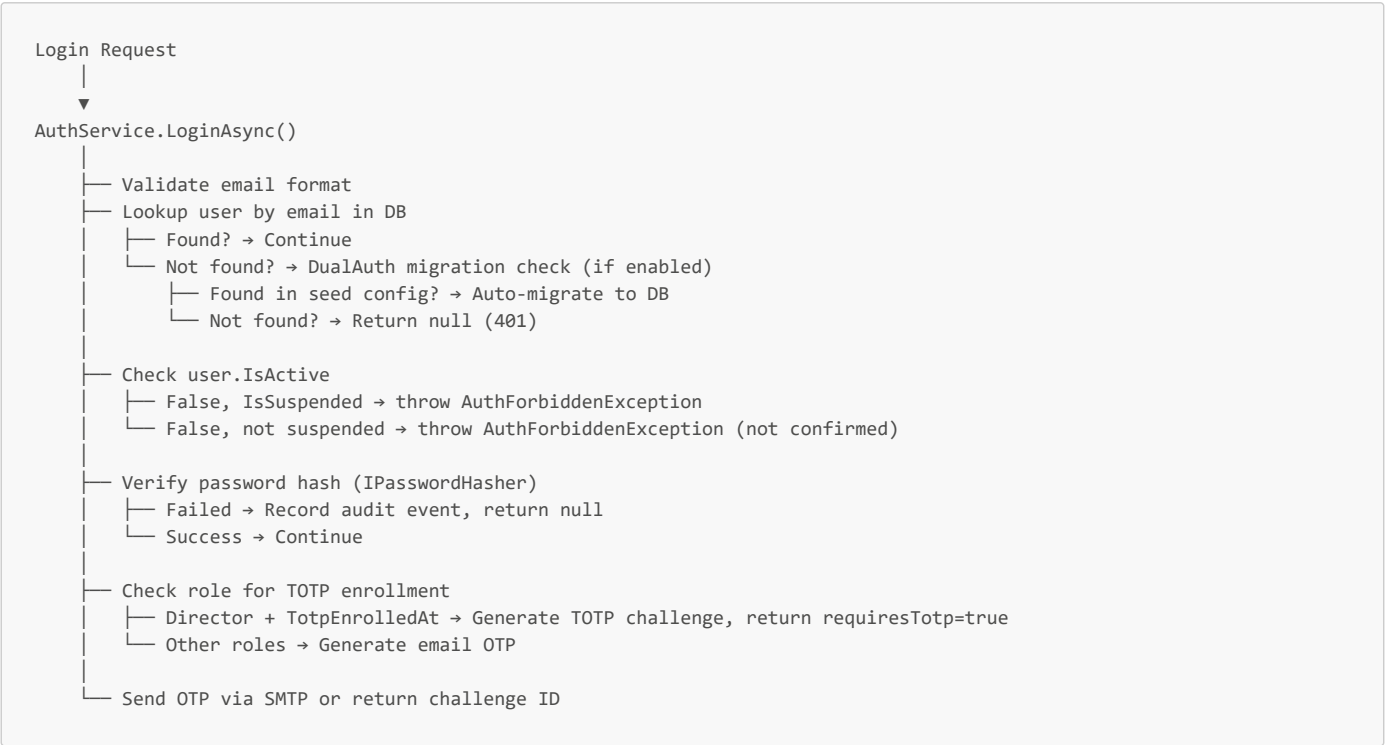
Encryption/decryption happens transparently in the application layer via EF Core value converters. The `EncryptPiiColumns` migration uses raw SQL with `USING` clauses to cast existing text data to `bytea`.

4.5 Audit Log Retention

- Audit events are never automatically deleted (immutable)
- `audit_digest_entries` are created by periodic jobs for digest delivery
- `CaseAnonymizationJob` anonymizes cases after 7 years (configurable)

5. Authentication & Authorization

5.1 Authentication Flow (Detailed)



5.2 JWT Token Structure

```
// Access Token (15 min TTL)
{
  "sub": "user-guid",
  "email": "user@example.com",
  "role": "Director",
  "organisation_id": "org-guid",
  "token_version": 0,
  "iat": 1700000000,
  "exp": 1700000900,
  "iss": "MidiKaval",
  "aud": "MidiKaval"
}
```

5.3 Token Security

- **Access tokens:** 15 minute expiry, no refresh
- **Refresh tokens:** 7 day expiry, stored in Redis as `refresh_token:{hash}`
- **Token rotation:** On refresh, old token is consumed and new one issued
- **Reuse detection:** If a consumed token is reused, all sessions for that user are invalidated
- **Token version:** `token_version` claim vs DB column — mismatch = 401
- **HttpOnly cookie:** Refresh token also stored in HttpOnly cookie scoped to `/api/v1/auth`

5.4 Authorization Policies

Defined in `AuthServiceCollectionExtensions.cs`:

```
// All policies also verify ActiveUserRequirement
options.AddPolicy("DirectorOnly", policy =>
    policy.RequireAuthenticatedUser()
        .RequireRole("Director")
        .AddRequirements(new ActiveUserRequirement()));
```

Policy	Roles Allowed	Used By
DirectorOnly	Director	Staff mgmt, admin, audit, GDPR

Policy	Roles Allowed	Used By
CoordinatorOrAbove	Director, Coordinator	Cases, visits, search
FieldWorker	SocialWorker, CaseWorker	Visits, sync, step-up
AccountantOrAbove	Director, Accountant	Budget management
VendorOnly	Vendor	Vendor API endpoints

5.5 2FA / TOTP Implementation

- **Library:** `Otp.NET 1.4.1`
- **Algorithm:** HMAC-SHA1
- **Step:** 30 seconds
- **Code length:** 6 digits
- **Verification window:** ± 1 step (allows clock drift)
- **Secret storage:** Base32-encoded, stored in `users.totp_secret`
- **Enrollment flow:** Generate → Store secret → Verify code → Mark enrolled
- **Login flow:** Only Directors get TOTP challenge during login (code gap — other roles can enroll but login goes through email OTP)

5.6 OTP Implementation

- **Library:** Custom `OtpHasher` (SHA256 hash of code)
- **Expiry:** 5 minutes (configurable)
- **Max attempts:** 5 per challenge
- **Storage:** Redis via `OtpChallengeStore`
- **Step-up OTP:** Separate flow for PII reveal, also Redis-backed

5.7 Dual-Auth Migration

When `DualAuth.Enabled = true`, the `AuthService` checks seed config sections if a user is not found in DB:

1. Check `Seed:Admin` section → creates Director user
2. Check `Seed:Vendor` section → creates Vendor user
3. Check `Seed:FieldWorker` section → creates field worker

This allows a migration window from config-file-based auth to database-backed auth.

5.8 Activation & Invitation Flow



5.9 `[Require2FA]` Attribute

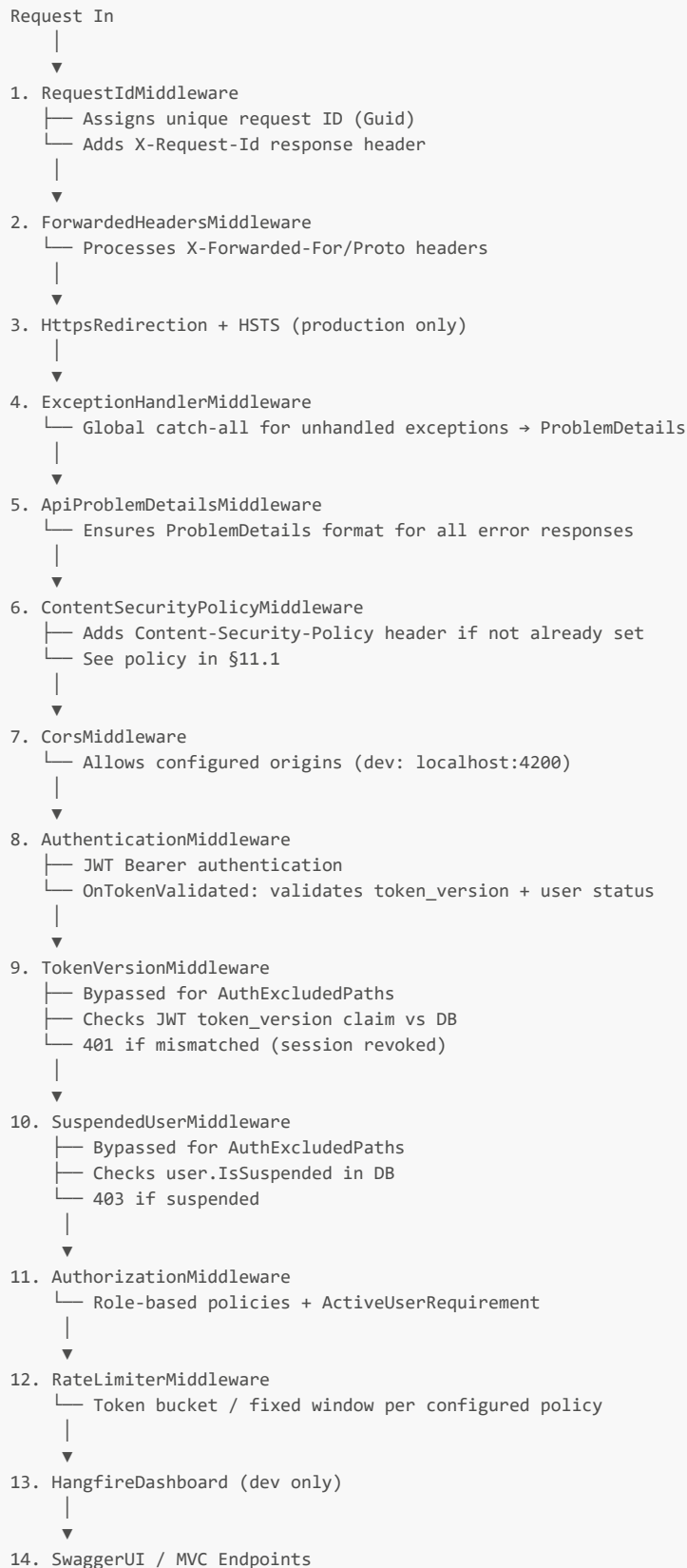
Applied at class level to restrict access to users with TOTP enrolled:

- `Admin.UsersController` — all user management endpoints
- `Admin.InvitationsController` — invitation management
- `Vendor.OrganisationsController` — vendor operations

Behavior: Returns 403 with message "Two-factor authentication is required to perform this action."

6. Middleware Pipeline

6.1 Pipeline Order (Execution Sequence)



6.2 Auth-Excluded Paths

The following paths bypass `TokenVersionMiddleware` and `SuspendedUserMiddleware`:

- `/health`
- `/swagger`
- `/api/v1/auth/login`
- `/api/v1/auth/verify-otp`
- `/api/v1/auth/refresh`
- `/api/v1/auth/logout`
- `/api/v1/auth/activate`

6.3 Key Middleware Details

TokenVersionMiddleware:

- Only acts on authenticated requests
- Reads `token_version` claim from JWT and compares to DB value
- Returns 401 if `jwt_version < db_version`
- This allows immediate session invalidation on password change / 2FA reset

SuspendedUserMiddleware:

- Only acts on authenticated requests
- Queries user's `IsSuspended` flag from DB
- Returns 403 if suspended

ContentSecurityPolicyMiddleware:

- Sets CSP header on every response if not already set
- Includes `report-uri /api/v1/security/csp-violation` for violation reporting

7. Background Jobs

7.1 Hangfire Configuration

- Storage:** PostgreSQL (if `Hangfire` connection string configured) or In-Memory (development)
- Server:** Started in-process with 20 workers
- Recurring jobs registered in `Program.cs`:**

Job	Schedule	Purpose
<code>InvitationCleanupJob</code>	Daily 2am	Clean expired invitations
<code>ZeroDirectorMonitorJob</code>	Hourly	Alert if org has no active Director

7.2 Background Services (Production Only)

The following services run as `IHostedService` background loops (registered via `AddHostedService<>`):

Service	Interval	Purpose
<code>InterventionOverdueBackgroundService</code>	Configurable	Flag overdue interventions
<code>CourtReminderBackgroundService</code>	Configurable	Send court reminder notifications
<code>CourtMissEscalationBackgroundService</code>	Configurable	Escalate missed court appearances
<code>ReportExportBackgroundService</code>	Configurable	Process async report generation jobs
<code>CaseAnonymizationBackgroundService</code>	24 hours	Anonymize cases past retention period
<code>AuditDigestBackgroundService</code>	5 minutes	Generate audit digest batches

7.3 Job Runner Pattern

Each background job follows a consistent runner pattern:

```
public class InterventionOverdueJobRunner(AppDbContext db, ...)
{
    public async Task ExecuteAsync(Cancellation token ct)
    {
        // 1. Query overdue items
```

```
        // 2. Update status flags
        // 3. Send notifications
        // 4. Log audit events
    }
}
```

Hangfire jobs call these runners. Background services call them on a timer.

8. Web Frontend Architecture

8.1 Angular Configuration

- **Version:** Angular 19.2 (standalone components, no NgModules)
- **Build system:** `@angular-devkit/build-angular`
- **SSR:** Not enabled (client-side SPA)
- **PWA:** Service worker enabled for offline caching
- **Port:** 4200 (development server)
- **CSS:** Angular Material theme + SCSS
- **HMR:** Component Hot Module Replacement enabled

8.2 Route Structure

Path	Component	Guard	Description
<code>/login</code>	LoginComponent	GuestGuard	Email/password login
<code>/login/otp</code>	OtpLoginComponent	OtpGuard	OTP code entry
<code>/login/totp</code>	TotpLoginComponent	— (self-check)	TOTP code entry
<code>/forgot-password</code>	ForgotPasswordComponent	GuestGuard	Request reset
<code>/reset-password</code>	ResetPasswordComponent	GuestGuard	Reset with token
<code>/activate</code>	ActivateComponent	GuestGuard	Organisation activation
<code>/accept-invitation</code>	InviteAcceptComponent	GuestGuard	Accept invitation
<code>/email-confirmed</code>	EmailConfirmedComponent	—	Confirmation success
<code>/dashboard</code>	DashboardComponent	AuthGuard	Main dashboard
<code>/cases</code>	CaseRegistryComponent	AuthGuard	Case search/list
<code>/cases/create</code>	CaseCreateComponent	AuthGuard	New case
<code>/cases/:id</code>	CaseDetailComponent	AuthGuard	Case detail
<code>/travel-claims</code>	TravelClaimsComponent	AuthGuard	My claims
<code>/visits/today</code>	TodayVisitsComponent	AuthGuard	Today's visits
<code>/visits/weekly</code>	WeeklyVisitsComponent	AuthGuard	Weekly schedule
<code>/visits/overdue</code>	OverdueVisitsComponent	AuthGuard	Overdue visits
<code>/budgets</code>	BudgetsListComponent	AuthGuard	Budget list
<code>/budgets/:id</code>	BudgetDetailComponent	AuthGuard	Budget detail
<code>/reports</code>	ReportsComponent	AuthGuard	Reports hub
<code>/admin/staff</code>	StaffListComponent	DirectorGuard	Staff directory
<code>/admin/audit</code>	AuditLogComponent	DirectorGuard	Audit log
<code>/admin/invitations</code>	InvitationsComponent	DirectorGuard	Manage invitations
<code>/vendor</code>	VendorComponent	VendorGuard	Vendor portal
<code>/legends</code>	LegendsComponent	AuthGuard	Reference data
<code>/import</code>	ImportComponent	AuthGuard	Data import
<code>/notifications</code>	NotificationsComponent	AuthGuard	Notification list
<code>/settings</code>	SettingsComponent	AuthGuard	User settings

8.3 Auth State Management

- **Storage:** `sessionStorage` (cleared on tab close)
- **Service:** `AuthSessionService` (injectable service with signals)
- **Key state:**
 - `accessToken`, `refreshToken` (stored in `sessionStorage`)
 - `currentUser` (id, email, role as Signal)
 - `isAuthenticated` Signal
 - `requiresTotp()` method
- **Token refresh:** Automatic via `AuthInterceptor` on 401 responses
- **Guards:** `AuthGuard`, `GuestGuard`, `DirectorGuard`, `VendorGuard` (route-level protection)

8.4 Key Dependencies (npm)

Package	Purpose
@angular/material	UI component library
@angular/cdk	Component dev kit
@angular/service-worker	PWA offline support
@fontsource/inter	Inter font family
material-icons	Icon library
@midi-kaval/api-client	Generated API client (workspace)
@midi-kaval/shared-types	Shared TypeScript types (workspace)
rxjs	Reactive extensions (~7.8)

8.5 API Integration

All API service classes follow a consistent pattern:

```
export class CasesApiService {
  constructor(private http: HttpClient) {}

  search(params: CaseSearchParams): Observable<ApiResponse<CaseSearchResult>> {
    return this.http.get<ApiResponse<CaseSearchResult>>(`
      ${environment.apiUrl}/api/v1/cases/search`,
      { params: this.toHttpParams(params) }
    );
  }
}
```

Base URL from environment: `environment.apiUrl = 'http://localhost:5049'`

9. Mobile App Architecture

9.1 React Native Configuration

- **Version:** React Native 0.76.9
- **React:** 18.3.1
- **Navigation:** `@react-navigation/native` + `native-stack` + `bottom-tabs`
- **Workspace name:** `@midi-kaval/mobile`

9.2 App Entry Point

```
// App.tsx
<SafeAreaProvider>
  <AuthProvider>
    <NavigationContainer ref={navigationRef}>
      <PushNotificationBootstrap />
      <RootNavigator />
    </NavigationContainer>
  </AuthProvider>
</SafeAreaProvider>
```

9.3 Navigation Structure



9.4 Key Native Features

Feature	Package	Usage
Push notifications	@react-native-firebase/app, messaging	Remote push alerts
Async storage	@react-native-async-storage/async-storage	Offline data cache
Date/time picker	@react-native-community/datetimepicker	Date selection
Geolocation	@react-native-community/geolocation	GPS capture
Network info	@react-native-community/netinfo	Connectivity detection
Gesture handling	react-native-gesture-handler	Touch interactions
Document picker	react-native-document-picker	Receipt upload
Keychain	react-native-keychain	Secure token storage
Safe area	react-native-safe-area-context	Device notch handling
Screens	react-native-screens	Native screen containers

9.5 Offline Sync Architecture

1. **Data capture:** All mutations are recorded in `sync_mutations` table with:
 - Entity type, mutation type (create/update/delete)
 - Serialized payload (JSON)
 - `is_pushed` flag (default: false)
2. **Sync push:** `POST /api/v1/sync/push` sends all pending mutations
3. **Sync pull:** Server returns relevant updates for the device
4. **Conflict resolution:** Last-write-wins (server timestamp comparison)

10. Infrastructure & DevOps

10.1 Docker Compose Configuration

```
services:
  postgres:
    image: postgres:16
    ports: ["5432:5432"]
    healthcheck: pg_isready -U kaval -d kaval_dev

  redis:
    image: redis:7
    ports: ["6379:6379"]
    healthcheck: redis-cli ping
```

```
azurite:
  image: mcr.microsoft.com/azure-storage/azurite:3.34.0
  ports: ["10000:10000"]
```

10.2 Development Scripts

All scripts in `/scripts/` (Windows Batch):

Script	What It Does
<code>_check-prereqs.bat</code>	Shared library: checks Docker, Node, .NET, ports, file existence, API health
<code>start-docker.bat</code>	<code>docker compose up -d</code> with health polling
<code>start-api.bat</code>	Checks prereqs → <code>dotnet run</code> in apps/api
<code>start-web.bat</code>	Checks prereqs → <code>npm install</code> → <code>ng serve --open</code> on port 4200
<code>start-mobile.bat</code>	Checks ADB → <code>adb reverse</code> → <code>npx react-native start</code> + <code>run-android</code>
<code>start-all.bat</code>	Orchestrates Docker → API → Web (optionally mobile) with <code>--all</code> flag
<code>stop-all.bat</code>	<code>taskkill</code> dotnet/node → <code>docker compose down -v</code> (optional)

10.3 Startup Sequence (Production)

```
1. docker compose up -d           # PostgreSQL, Redis, Azurite
2. dotnet run --project apps/api   # API applies migrations + seeds
3. ng serve --host 0.0.0.0        # Angular dev server
```

For mobile:

```
4. adb reverse tcp:5049 tcp:5049 # API proxy
5. npx react-native start         # Metro bundler
6. npx react-native run-android   # Install & launch on device
```

10.4 Build & CI

- Solution build: `dotnet build Midi-Kaval.slnx`
- API client generation: `npm run generate:api-client` (from OpenAPI spec)
- Shared types: `npm run build:shared-types`
- E2E tests: `tests/e2e` (npm workspace)

11. Security & Compliance

11.1 Content Security Policy (CSP)

From API middleware (`ContentSecurityPolicyMiddleware`):

```
default-src 'self';
script-src 'self' 'unsafe-inline';
style-src 'self' 'unsafe-inline';
img-src 'self' data: blob:;
connect-src 'self';
font-src 'self';
object-src 'none';
base-uri 'self';
form-action 'self';
frame-ancestors 'self';
report-uri /api/v1/security/csp-violation;
```

From Angular `index.html` (meta tag, overrides middleware for SPA):

```
default-src 'self';
script-src 'self' 'unsafe-inline';
```

```
style-src 'self' 'unsafe-inline';
img-src 'self' data: blob:;
connect-src 'self' http://localhost:5049; ← allows API calls
font-src 'self';
object-src 'none';
base-uri 'self';
form-action 'self';
```

Violation reports are POSTed to </api/v1/security/csp-violation>.

11.2 PII Protection

Measure	Implementation
Encryption at rest	Column-level bytea storage for beneficiary PII
Access control	Step-up OTP required for PII reveal
Audit trail	All PII access logged in audit_events
Erasure	GDPR erasure endpoint (Director only)
Portability	JSON export for personal data
Anonymization	Automatic after 7-year retention period
Audit log redaction	PII redacted from audit logs after retention

11.3 Rate Limiting

All endpoints protected by token-bucket rate limiter:

- Auth endpoints: 10 requests/minute/IP
- Data reads: 100 requests/minute/IP (Directors bypass)
- Data writes: 20 requests/minute/IP (Directors bypass)
- Vendor: 10 write / 60 read per minute per user

Rate limit violation returns [429 Too Many Requests](#) with [Retry-After: 60](#) header.

11.4 Session Security

Feature	Detail
JWT signing	HMAC-SHA256 with configurable key
Refresh token	Opaque, stored as SHA256 hash in Redis
Token rotation	New token issued on each refresh
Reuse detection	Stolen token reuse → all sessions invalidated
Token version	DB column tracks version, JWT claim validated
HttpOnly cookie	Refresh token in cookie scoped to /api/v1/auth

11.5 Data Retention

- Case data retained for **7 years** (configurable)
- After retention: automated anonymization job
- Anonymization zeroes out: name, contact, PII fields
- Audit events retained indefinitely (immutable log)
- Soft delete for budgets (utilizations get [deleted_at_utc](#))

12. Development Setup

12.1 Prerequisites

Tool	Version	Purpose
Docker Desktop	Latest	PostgreSQL, Redis, Azurite
.NET SDK	≥ 8.0	API backend
Node.js	≥ 18	Web + Mobile frontends

Tool	Version	Purpose
Android SDK	Latest	Mobile app builds
ADB	Included in SDK	Android device communication

12.2 Quick Start

```
# 1. Start infrastructure
scripts\start-docker.bat

# 2. Start API (in a new terminal)
scripts\start-api.bat

# 3. Start Web (in a new terminal)
scripts\start-web.bat

# 4. Or start everything with one command
scripts\start-all.bat
```

12.3 Configuration

Key settings in `apps/api/appsettings.Development.json`:

Setting	Default	Notes
<code>ConnectionStrings:DefaultConnection</code>	<code>Host=localhost;Port=5432;Database=kaval_dev;Username=kaval;Password=kaval_dev</code>	PostgreSQL
<code>ConnectionStrings:Redis</code>	<code>localhost:6379</code>	Redis
<code>Jwt:SigningKey</code>	<code>CHANGE_ME_USE_USER_SECRETS_MIN_32_CHARS</code>	Must be 32+ chars
<code>Seed:Admin:Email</code>	<code>director@pilot.example</code>	Default admin login
<code>Seed:Vendor:Email</code>	<code>karthik.k.82@outlook.com</code>	Default vendor login
<code>Seed:Admin:Password</code>	<code>CHANGE_ME</code>	Default password
<code>Email:Smtp:Host</code>	<code>smtp.gmail.com</code>	SMTP for OTP
<code>BlobStorage:ConnectionString</code>	Azurite connection string	Local blob emulator
<code>DualAuth:Enabled</code>	<code>true</code>	Config-to-DB migration

12.4 Adding Migrations

```
# From apps/api directory
dotnet ef migrations add MigrationName
dotnet ef database update
```

Migrations auto-apply on startup via `DatabaseInitializer.ApplyMigrationsAndSeedAsync()`.

13. Testing Strategy

13.1 Unit Tests

- **Framework:** xUnit
- **Project:** `tests/api.unit/MidiKaval.Api.UnitTests.csproj`
- **Coverage targets:** Services, domain logic, validation
- **Mocking:** Standard mocking via interfaces

13.2 Integration Tests

- **Framework:** xUnit + WebApplicationFactory
- **Project:** tests/api.integration/MidiKaval.Api.IntegrationTests.csproj
- **Database:** Test container or in-memory PostgreSQL
- **Covers:** Auth flows, case CRUD, visit lifecycle, budget workflows

13.3 Run Tests

```
# All tests
dotnet test Midi-Kaval.slnx

# By category
dotnet test --filter "FullyQualifiedName~Auth"
dotnet test --filter "FullyQualifiedName~Cases"
dotnet test --filter "Category=Unit"
dotnet test --filter "Category=Integration"
```

13.4 Test Projects Reference

```
<ProjectReference Include="..\..\apps\api\MidiKaval.Api.csproj" />
<InternalsVisibleTo Include="MidiKaval.Api.UnitTests" />
```

Appendix A: NuGet Dependencies

Package	Version	Purpose
Microsoft.AspNetCore.Authentication.JwtBearer	8.0.11	JWT auth
Microsoft.EntityFrameworkCore	8.0.11	ORM core
Npgsql.EntityFrameworkCore.PostgreSQL	8.0.11	PostgreSQL provider
EFCore.NamingConventions	8.0.3	SnakeCase naming
Swashbuckle.AspNetCore	6.6.2	Swagger
Microsoft.Extensions.Caching.StackExchangeRedis	8.0.11	Redis cache
System.IdentityModel.Tokens.Jwt	8.3.0	JWT handling
Otp.NET	1.4.1	TOTP generation
FirebaseAdmin	3.2.0	Push notifications
Hangfire.AspNetCore	1.8.23	Background jobs
Hangfire.PostgreSql	1.21.1	Hangfire PG storage
Azure.Storage.Blobs	12.23.0	Blob storage
ClosedXML	0.104.2	Excel export
QuestPDF	2024.12.3	PDF generation
MailKit	4.11.0	SMTP email
Microsoft.Extensions.Identity.Core	8.0.11	Password hashing

Appendix B: Environment Variables

Variable	Purpose	Default
RUN_MIGRATION	Trigger dual-auth config-to-DB migration	Not set
ASPNETCORE_ENVIRONMENT	Runtime environment	Development
ASPNETCORE_URLS	API listen URL	http://localhost:5049

Appendix C: Application Constants

Constant	Value	Location
Vendor Organisatioid	00000000-0000-0000-0000-000000000001	VendorUserSeeder
Access Token TTL	15 minutes	JwtOptions
Refresh Token TTL	7 days	RefreshTokenOptions
OTP Expiry	5 minutes	OtpOptions
OTP Max Attempts	5	OtpOptions
TOTP Step	30 seconds	TotpOptions
TOTP Code Length	6 digits	TotpOptions
TOTP Verification Window	±1 step	TwoFactorService
Retention Period	7 years	CaseAnonymizationJobOptions
CSP Report Endpoint	/api/v1/security/csp-violation	ContentSecurityPolicyMiddleware